0.1 Passwortsicherheit

0.1.1 Einleitung

In fast allen IT-Systemen bilden Passwörter die erste Hürde gegen unbefugten Zugriff. In der Praxis zeigt sich jedoch immer wieder, dass schwache, kompromittierte oder mehrfach genutzte Passwörter eine der grössten Sicherheitslücken darstellen. Dieses Skript gibt einen Überblick über die mathematischen Grundlagen der Passwort-Stärke und fasst die aktuellen Empfehlungen zur Absicherung digitaler Identitäten zusammen [2].

0.1.2 Grundlegende Begriffe und Angriffsarten

In der Authentisierung und Passwort-Sicherheit spielen verschiedene Konzepte und Bedrohungen eine entscheidende Rolle:

Neben dem rein mathematischen Brute-Force-Angriff nutzen Angreifer in der Praxis sehr häufig ein Dictionary Attack (Wörterbuchangriff), bei dem gezielt Listen mit geläufigen Wörtern, Namen und bekannten Daten durchprobiert werden. Um diesen Methoden zu entgehen, ist eine hohe Entropie entscheidend. Zusätzlich schützt moderne Multi-Faktor-Authentisierung (MFA) (z. B. eine Bestätigung direkt auf dem Smartphone) effektiv vor unbefugtem Zugriff.

0.1.3 Mathematische Grundlage: Die Passwort-Entropie

Die Stärke eines Passworts gegenüber Angriffen lässt sich mathematisch über die Shannon-Entropie beschreiben. Sie gibt an, wie viele Versuche ein Angreifer im schlechtesten Fall benötigt, um den gesamten Suchraum zu durchsuchen.

Die Formel zur Berechnung der Entropie E (in Bit) lautet:

$$E = L \cdot \log_2(R)$$

Dabei stehen die Variablen für folgende Werte:

- L: Die Länge des Passworts (Anzahl der verwendeten Zeichen).
- R: Die Grösse des verfügbaren Zeichensatzes (z. B. Kleinbuchstaben, Grossbuchstaben, Zahlen, Sonderzeichen).

0.1.4 Beispielrechnung

- **8 Zeichen (nur Kleinbuchstaben):** Bei $L = 8$ und einem Zeichensatz von $R = 26$ ergibt sich eine Entropie von:

$$E_8 = 8 \cdot \log_2(26) \approx 37{,}6 \text{ Bit}$$

- **Verdopplung auf 16 Zeichen (gleicher Zeichensatz):** Bei $L = 16$ und $R = 26$ steigt die Entropie linear mit der Länge auf:

$$E_{16} = 16 \cdot \log_2(26) \approx 75{,}2 \text{ Bit}$$

In Tabelle 1 sind die Entropie-Werte für verschiedene Passwort-Längen und Zeichensätze zusammenfassend dargestellt.

Zeichensatz (R)	**Länge** (L)	**Formel**	**Entropie** (E)
Kleinbuchstaben ($R = 26$)	8	$8 \cdot \log_2(26)$	$\approx 37{,}6$ Bit
Kleinbuchstaben ($R = 26$)	16	$16 \cdot \log_2(26)$	$\approx 75{,}2$ Bit
Alle Zeichen ($R = 94$)	8	$8 \cdot \log_2(94)$	$\approx 52{,}4$ Bit
Kleinbuchstaben ($R = 26$)	20	$20 \cdot \log_2(26)$	$\approx 94{,}0$ Bit
Alle Buchstaben ($R = 52$)	20	$20 \cdot \log_2(52)$	$\approx 114{,}0$ Bit
Alle Buchstaben + Zahlen ($R = 62$)	20	$20 \cdot \log_2(62)$	$\approx 119{,}1$ Bit
Alle Zeichen ($R = 94$)	20	$20 \cdot \log_2(94)$	$\approx 131{,}1$ Bit

Tabelle 1: Vergleich der Passwort-Entropie für verschiedene Längen und Zeichensätze.

0.1.5 Fazit der Berechnung

Da die Anzahl der auszuprobierenden Kombinationen im Hintergrund exponentiell mit 2^E (E=Entropie) wächst, schützt das Verlängern des Passworts um ein Vielfaches effektiver vor Angriffen als das krampfhafte Einfügen von Sonderzeichen bei einem zu kurzen Passwort. Zudem verhindert ein langes, zufälliges Passwort, dass ein Dictionary Attack (Wörterbuchangriff) erfolgreich ist.

0.1.6 Aktuelle Richtlinien und Best Practices

Moderne Richtlinien haben sich von alten Regeln verabschiedet. Heute gelten folgende Hauptempfehlungen:

1. **Länge vor Komplexität:** Bevorzugung von Passphrasen aus mehreren zufälligen Wörtern. Selbst wenn Angreifer raffinierte Wörterbuchangriffe oder Kombinationen ausprobieren, bricht ein System bei langen Passphrasen (oft auch ohne erzwungene Sonderzeichen) ein, weil die schiere Länge den Suchraum unknackbar macht (Entropie über 80 Bit).
2. **Keine wiederholte Nutzung von Passwörtern:** Jedes Konto sollte ein einzigartiges Passwort besitzen, um die Risiken bei Datenlecks zu minimieren.
3. **Vermeidung von Passwort-Änderungen ohne Anlass:** Regelmässige erzwungene Passwort-Änderungen erhöhen die Wahrscheinlichkeit, dass Nutzer schwächere Passwörter wählen oder diese aufschreiben. Nur bei Verdacht auf Kompromittierung sollte ein Passwort geändert werden.
4. **Einsatz von Passwort-Manager:** Generierung und Verwaltung unikater Passwort.
5. **Aktivierung von MFA:** Einrichtung eines zweiten Faktors (z. B. aufs Smartphone).

0.2 Phishing

0.2.1 Einleitung

In der digitalen Welt bilden nicht nur technische Barrieren wie Passwörter die Abwehrlinie, sondern vor allem der Mensch selbst. Eines der erfolgreichsten und am häufigsten genutzten Einfallstore für Cyberkriminelle ist Phishing. Dabei wird gezielt die menschliche Psyche ausgenutzt, um an vertrauliche Daten zu gelangen oder Schadsoftware zu verbreiten [1].

0.2.2 Grundlegende Begriffe und Angriffsarten

Phishing gehört zu den klassischen Social Engineering-Angriffen. Statt komplexe technische Systeme direkt zu hacken, manipulieren Angreifer gezielt Personen:

- **Klassisches Phishing:** Täuschend echte E-Mails, die vorgeben, von vertrauenswürdigen Institutionen (wie Banken, Streaming-Diensten oder Behörden) zu stammen.
- **Spear-Phishing:** Ein gezielter Angriff (Spear-Phishing), der auf eine spezifische Person oder bestimmte Mitarbeiter zugeschnitten ist, um Vertrauen zu erwecken.
- **Vishing & Smishing:** Betrugsversuche über Telefonanrufe (*Voice* → *Vishing*) oder Kurznachrichten (*SMS* → *Smishing*).
- **Quishing:** Das Platzieren von manipulierten QR-Codes (z. B. auf Plakaten oder Parkuhren), die zu gefälschten Webseiten führen.

0.2.3 Psychologische Faktoren und Wirkungsweise

Im Gegensatz zu mathematischen Angriffen zielt Phishing auf menschliche Schwachstellen wie Neugier, Hilfsbereitschaft, Gier oder vor allem **Angst und Zeitdruck** ab. Typische Maschen beinhalten drohende Konsequenzen wie angebliche Kontosperrungen, dringende Rechnungen oder verpasste Gewinne, damit das Opfer unüberlegt handelt.

0.2.4 Aktuelle Richtlinien und Best Practices

Um sich vor Phishing-Angriffen zu schützen, gelten im Rahmen der IT-Sicherheit folgende zentrale Empfehlungen:

1. **Kritische Hürden bewahren:** Niemals unüberlegt auf Links klicken oder Anhänge von unbekannten Absendern öffnen.
2. **Absender und URLs genau prüfen:** Auf Unstimmigkeiten in E-Mail-Adressen (z. B. Buchstabendreher (Typosquatting)) in Domains achten.
3. **Multi-Faktor-Authentisierung (MFA) nutzen:** Selbst wenn Anmeldedaten abgegriffen werden, verhindert ein zusätzlicher Faktor (wie eine Bestätigung auf dem Smartphone) unbefugten Zugriff.
4. **Keine sensiblen Daten preisgeben:** Seriöse Institutionen fragen niemals per E-Mail, SMS oder Telefon nach Passwörtern oder PINs.
5. **Dringlichkeit und Druckmittel hinterfragen:** E-Mails, die mit unbegründeten Drohungen (z. B. sofortige Kontosperrung) oder kurzen Fristen Panik erzeugen wollen, kritisch prüfen.
6. **Sprache und Anrede analysieren:** Auf unpersönliche Anreden (z. B. Sehr geehrter Kunde) sowie grammatikalische Fehler, fehlende Umlaute oder ungewöhnliche Formulierungen achten.
7. **Direktzugriffe bevorzugen:** Webseiten und Portale stets manuell über die Eingabe der bekannten Adresse im Browser aufrufen, anstatt Links aus E-Mails zu folgen.

0.3 Übungsaufgaben

Dieser Abschnitt enthält Vertiefungs- und Übungsaufgaben zu den Themen aus Abschnitt 0.1 und Abschnitt 0.2.

0.3.1 Aufgabenblatt 1: Passwortsicherheit

0.3.1.1 Teil 1: Begriffsdefinitionen & Grundlagen

Aufgabe 2.3.1.1.1: Begriffsdefinitionen

Erklären Sie kurz in Ihren eigenen Worten den Unterschied zwischen einem Brute-Force-Angriff und einem Dictionary Attack (Wörterbuchangriff).

Musterlösung 2.3.1.1.1

- **Brute-Force-Angriff:** Ein automatisierter Angriff, bei dem Programme systematisch alle möglichen Zeichenkombinationen durchprobieren.
- **Dictionary Attack (Wörterbuchangriff):** Ein gezielter Angriff, bei dem Listen mit gebräuchlichen Wörtern, Namen und bekannten Passwörtern systematisch getestet werden.

Aufgabe 2.3.1.1.2: MFA

Was bedeutet die Abkürzung MFA und wie schützt sie einen Account, selbst wenn ein Angreifer das Passwort herausgefunden hat?

Musterlösung 2.3.1.1.2

MFA steht für **Multi-Faktor-Authentisierung**. Sie schützt einen Account, indem neben dem Passwort ein zweiter Faktor (z. B. eine Bestätigung auf dem Smartphone) erforderlich ist. Selbst wenn ein Angreifer das Passwort erlangt hat, bleibt der Zugriff ohne diesen zweiten Faktor verwehrt.

0.3.1.2 Teil 2: Mathematische Berechnungen (Entropie)

Verwenden Sie die Formel zur Berechnung der Entropie aus Abschnitt 0.1.3 (sehen Sie auch Tabelle 1):

$$E = L \cdot \log_2(R)$$

Aufgabe 2.3.1.2.1: Einfluss des Zeichensatzes (R)

Gegeben ist ein Passwort der Länge $L = 10$.

a) Berechnen Sie die Entropie E, wenn nur Kleinbuchstaben verwendet werden ($R = 26$).

b) Berechnen Sie die Entropie E, wenn Klein-, Grossbuchstaben, Zahlen und Sonderzeichen verwendet werden ($R = 94$).

Musterlösung 2.3.1.2.1

a) $E = 10 \cdot \log_2(26) \approx 10 \cdot 4{,}7004 = 47{,}0$ Bit

b) $E = 10 \cdot \log_2(94) \approx 10 \cdot 6{,}5546 = 65{,}5$ Bit

Aufgabe 2.3.1.2.2: Länge vs. Komplexität

Betrachten Sie die folgenden beiden Passwörter:

- **Szenario A:** Ein komplexes Passwort mit 8 Zeichen ($L = 8$), das Kleinbuchstaben, Grossbuchstaben, Zahlen und Sonderzeichen nutzt ($R = 94$).
- **Szenario B:** Ein zufälliges Passwort mit 20 Zeichen ($L = 20$), das nur aus Kleinbuchstaben besteht ($R = 26$).

Aufgabe: Berechnen Sie für beide Szenarien die Entropie E. Welches Passwort bietet eine höhere Entropie und warum entspricht dies der Regel Länge vor Komplexität?

Musterlösung 2.3.1.2.2

- **Szenario A ($L = 8, R = 94$):** $E_A = 8 \cdot \log_2(94) \approx 52{,}4$ Bit
- **Szenario B ($L = 20, R = 26$):** $E_B = 20 \cdot \log_2(26) \approx 94{,}0$ Bit

Auswertung & Begründung: Szenario B bietet eine deutlich höhere Entropie (94,0 Bit) als Szenario A (52,4 Bit). Da der Suchraum im Hintergrund exponentiell mit 2^E (E=Entropie) wächst, vergrössert eine Zunahme der Länge (L) den Suchraum wesentlich stärker als ein grösserer Zeichensatz (R). Dies entspricht der Regel Länge vor Komplexität.

0.3.1.3 Teil 3: Anwendung & Best Practices

Aufgabe 2.3.1.3.1: Richtlinien beurteilen

Welche der folgenden Aussagen entsprechen den aktuellen Best Practices (z. B. nach National Institute of Standards and Technology (NIST))? Begründen Sie Ihre Antwort kurz.

A) Ein sicheres Passwort muss alle 30 Tage geändert werden.
B) Passphrasen aus mehreren zufälligen Wörtern sind in der Regel sicherer und merkbarer als kurze, komplexe Zeichenketten.
C) Verwenden Sie das gleiche Passwort für mehrere Dienste, solange es sehr lang ist.
D) Der Einsatz eines Passwort-Manager wird empfohlen, um für jeden Dienst ein unikat zufälliges Passwort zu generieren.

Musterlösung 2.3.1.3.1

A) **Falsch:** Regelmässige erzwungene Änderungen verleiten Nutzer zu schwächeren Passwörtern oder Mustern. Eine Änderung sollte nur bei Verdacht auf Kompromittierung erfolgen.
B) **Richtig (Best Practice):** Passphrasen bieten durch ihre Länge eine hohe Entropie (über 80 Bit) und sind widerstandsfähiger gegen Angriffe.
C) **Falsch:** Passwörter dürfen niemals mehrfach genutzt werden, um Folgeschäden bei Datenlecks zu verhindern.
D) **Richtig (Best Practice):** Ein Passwort-Manager ermöglicht die sichere Generierung und Verwaltung von einzigartigen Passwörtern für jeden Dienst.

0.3.2 Aufgabenblatt 2: Phishing, Social Engineering & Best Practices

0.3.2.1 Teil 1: Verständnis & Begriffe

Aufgabe 2.3.2.1.1: Begriffsdefinitionen & Abgrenzung

Erklären Sie kurz in Ihren eigenen Worten den Unterschied zwischen klassischem Phishing und gezieltem Spear-Phishing. Gehen Sie dabei darauf ein, wer jeweils das Ziel des Angriffs ist.

Musterlösung 2.3.2.1.1

- **Klassisches Phishing:** Richtet sich ungezielt an eine breite Masse von Personen
  (z. B. gefälschte Massen-E-Mails im Namen bekannter Unternehmen).
- **Spear-Phishing:** Ein hochspezifischer, massgeschneiderter Angriff auf eine einzelne ausgewählte Person oder eine konkrete Mitarbeitergruppe innerhalb einer Organisation.

Aufgabe 2.3.2.1.2: Gefahrenkanäle (Vishing, Smishing & Quishing)

Cyberkriminelle nutzen nicht nur E-Mails. Ordnen Sie den folgenden Angriffsformen die passende Methode zu und erklären Sie kurz, worauf man achten muss:

a) **Vishing**
b) **Smishing**
c) **Quishing**

Musterlösung 2.3.2.1.2

a) **Vishing (Voice Phishing):** Phishing über Telefonanrufe.
   Beachtung: Seriöse Anrufer verlangen niemals Passwörter oder PINs am Telefon.
b) **Smishing (SMS Phishing):** Betrug über Kurznachrichten (SMS).
   Beachtung: Keine unüberlegten Klicks auf SMS-Links und keine Preisgabe vertraulicher Daten.
c) **Quishing (QR-Code Phishing):** Platzierung gefälschter QR-Codes.
   Beachtung: Ziel-URL vor dem Aufrufen im Scanner genau prüfen.

Aufgabe 2.3.2.1.3: Multi-Faktor-Authentisierung (MFA)

Warum ist MFA eines der effektivsten Schutzmittel gegen Phishing?
Wie schützt MFA einen Account, selbst wenn ein Opfer seine Anmeldedaten auf einer gefälschten Phishing-Website eingegeben hat?

Musterlösung 2.3.2.1.3

MFA ist extrem effektiv, da Passwörter alleine für eine erfolgreiche Übernahme nicht ausreichen. Selbst wenn ein Opfer sein Passwort auf einer Phishing-Webseite eingibt, scheitert der Angreifer beim Anmeldeversuch, weil die Bestätigung über den zweiten Faktor (z. B. Smartphone-App) fehlt.

0.3.2.2 Teil 2: Psychologische Faktoren & Szenario-Analyse

Aufgabe 2.3.2.2.1: Psychologische Tricks

Social Engineering nutzt primär menschliche Schwachstellen statt technischer Systemlücken. Nennen Sie drei psychologische Faktoren, die Angreifer gezielt ausnutzen, und beschreiben Sie kurz, wie diese einen Menschen zu unüberlegtem Handeln verleiten.

Musterlösung 2.3.2.2.1

1. **Angst:** Drohungen wie Kontosperrungen erzeugen Panik, sodass Logik und Vorsicht ausgeschaltet werden.
2. **Zeitdruck / Dringlichkeit:** Kurze Fristen verleiten dazu, übereilt und unüberlegt zu handeln.
3. **Neugier / Gier:** Versprechen von Gewinnen oder exklusiven Informationen verleiten zum unkritischen Klicken auf Links.

In Abbildung 1 ist eine typische verdächtige Nachricht für die nachfolgende Szenario-Analyse dargestellt.

Phishing-E-Mail-Verdachtsfall

Von: `support-service@bank-security-check.ch`
An: `max.muster@kanti.ch`
Betreff: DRINGEND: Ihr Konto wird in 2 Stunden gesperrt!

Sehr geehrter Kunde,

aufgrund verdächtiger Aktivitäten müssen Sie Ihre Daten sofort verifizieren.
Wenn Sie nicht innerhalb von 120 Minuten handeln, wird Ihr Zugang dauerhaft gesperrt.

Klicken Sie hier: `http://www.kanton-bank-login-sicherheit.com/verify`

Abbildung 1: Verdächtiges E-Mail-Fallbeispiel für die Szenario-Analyse.

Aufgabe 2.3.2.2.2: Fallbeispiel Szenario-Analyse

Lesen Sie die in Abbildung 1 dargestellte Nachricht aufmerksam durch.

a) Identifizieren Sie mindestens drei Merkmale in dieser Nachricht, die eindeutig auf einen Phishing-Angriff hinweisen.

b) Welche Form von Phishing und welcher psychologische Mechanismus liegen hier vor?

Musterlösung 2.3.2.2.2

a) **Drei Verdachtsmerkmale:**
- *Verdächtige Absender- und Ziel-URL:* Weder `@bank-security-check.ch` noch die Domain `kanton-bank-login-sicherheit.com` stammen von einer offiziellen Bank.
- *Unpersönliche Anrede:* Generische Anrede Sehr geehrter Kunde.
- *Massiver Zeitdruck und Drohung:* Fristsetzung von 120 Minuten mit Androhung einer dauerhaften Kontosperrung.

b) **Form & Psychologie:** Es handelt sich um **klassisches Phishing**. Der psychologische Mechanismus basiert auf Angst und künstlich erzeugtem Zeitdruck.

0.3.2.3 Teil 3: Anwendung & Best Practices (Richtlinien beurteilen)

Aufgabe 2.3.2.3.1: Richtlinien beurteilen

Beurteilen Sie die folgenden Aussagen. Ist die Aussage **Richtig** oder **Falsch**? Begründen Sie Ihre Antwort jeweils kurz in einem bis drei Sätzen.
Aussage A: Seriöse Banken und Institutionen fordern Kunden gelegentlich per E-Mail auf, ihr Passwort einzugeben, um die Identität bei Sicherheitsupdates zu bestätigen.
Aussage B: Beim Aufruf von Links sollte stets die exakte URL (Internetadresse) geprüft werden, da Angreifer häufig Buchstabendreher oder gefälschte Subdomains (Typosquatting) nutzen.
Aussage C: Ein Phishing-Angriff kann nur dann erfolgreich sein, wenn auf einem Computer keine Antiviren-Software installiert ist.
Aussage D: Das Scannen von QR-Codes auf Plakaten oder Parkuhren ist völlig risikofrei, da QR-Codes keine Viren oder Links enthalten können.

Musterlösung 2.3.6.1

- **Aussage A: Falsch.** Seriöse Institutionen fragen niemals per E-Mail, SMS oder Telefon nach Passwörtern oder PINs.
- **Aussage B: Richtig.** Angreifer versuchen oft, Opfer durch täuschend ähnliche Domains oder gefälschte Subdomains (Typosquatting) in die Irre zu führen.
- **Aussage C: Falsch.** Phishing nutzt primär die menschliche Psyche (Social Engineering). Eine Antiviren-Software schützt nicht davor, dass der Nutzer seine Daten selbst auf einer gefälschten Website eingibt.
- **Aussage D: Falsch.** Beim Quishing werden QR-Codes auf schädliche oder gefälschte Zielseiten verlinkt, was ein erhebliches Sicherheitsrisiko darstellt.